



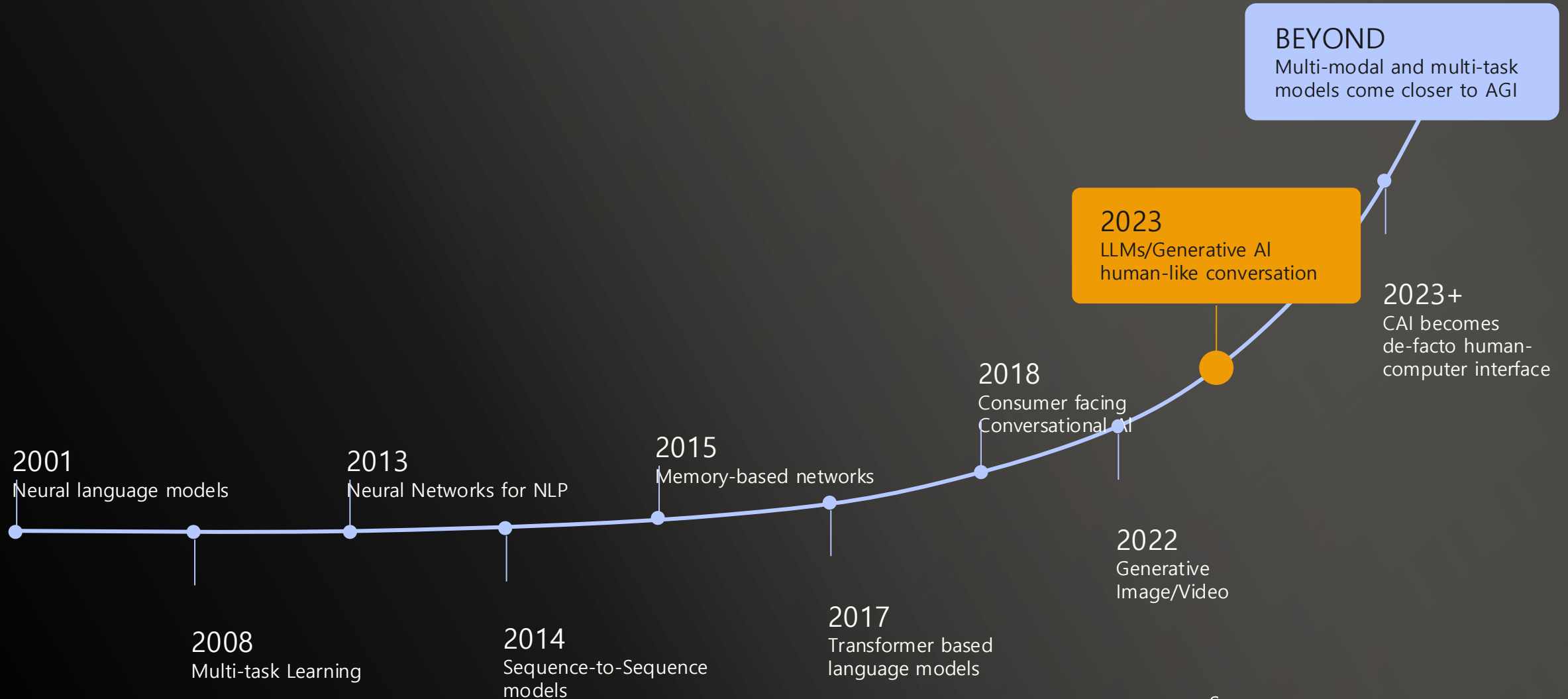
안전한 AI Agent 개발, 무엇을 고려해야 하는가

Auth0를 활용한 AI Agent 및 MCP 인증/인가 구현

장희재 / Heejae Chang
Okta Korea 기술 총괄 전무 / Principal Solutions Engineer, Okta

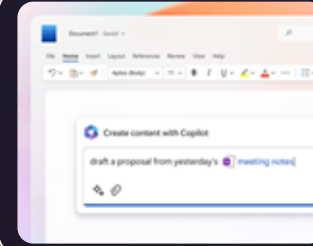


AI 활용은 이제 많은 앱의 필수 요소가 되었습니다



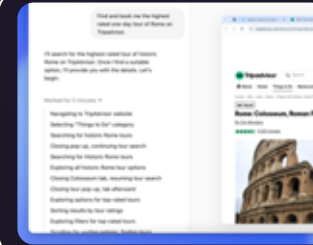
AI 에이전트는 우리가 일하는 방식을 어떻게 바꾸고 있을까요?

단순한 챗봇의 시기는 이미 지났습니다



영어, 한국어 및 모든 자연어가 프로그래밍을 위한 언어가 되었습니다

CoPilot by Microsoft



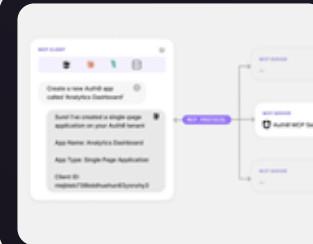
단순 반복 업무가 사라지고 있습니다. 심지어 여러 앱과 API를 연계해야 하는 경우도 마찬가지입니다

OpenAI



최소한 혹은 아예 사용자 인터렉션 없이 에이전트가 자율적으로 동작하며 업무를 수행합니다.

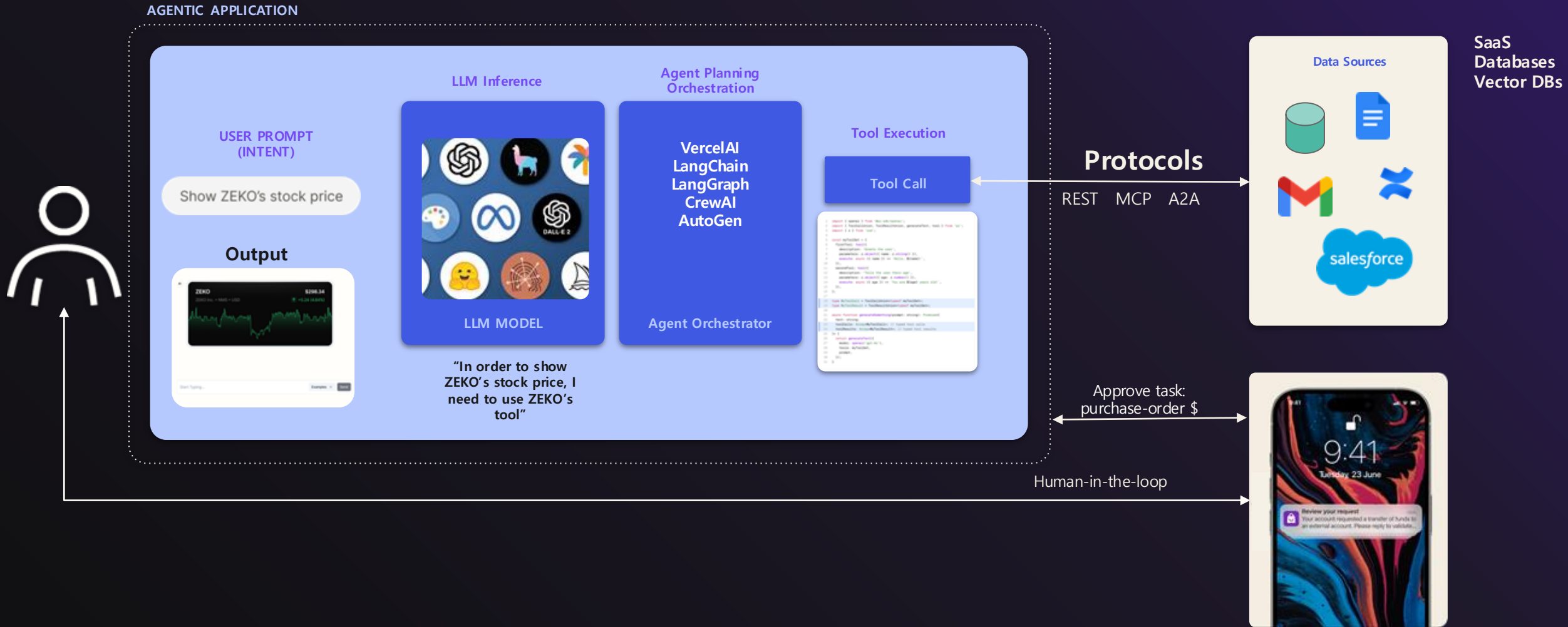
OpenAI



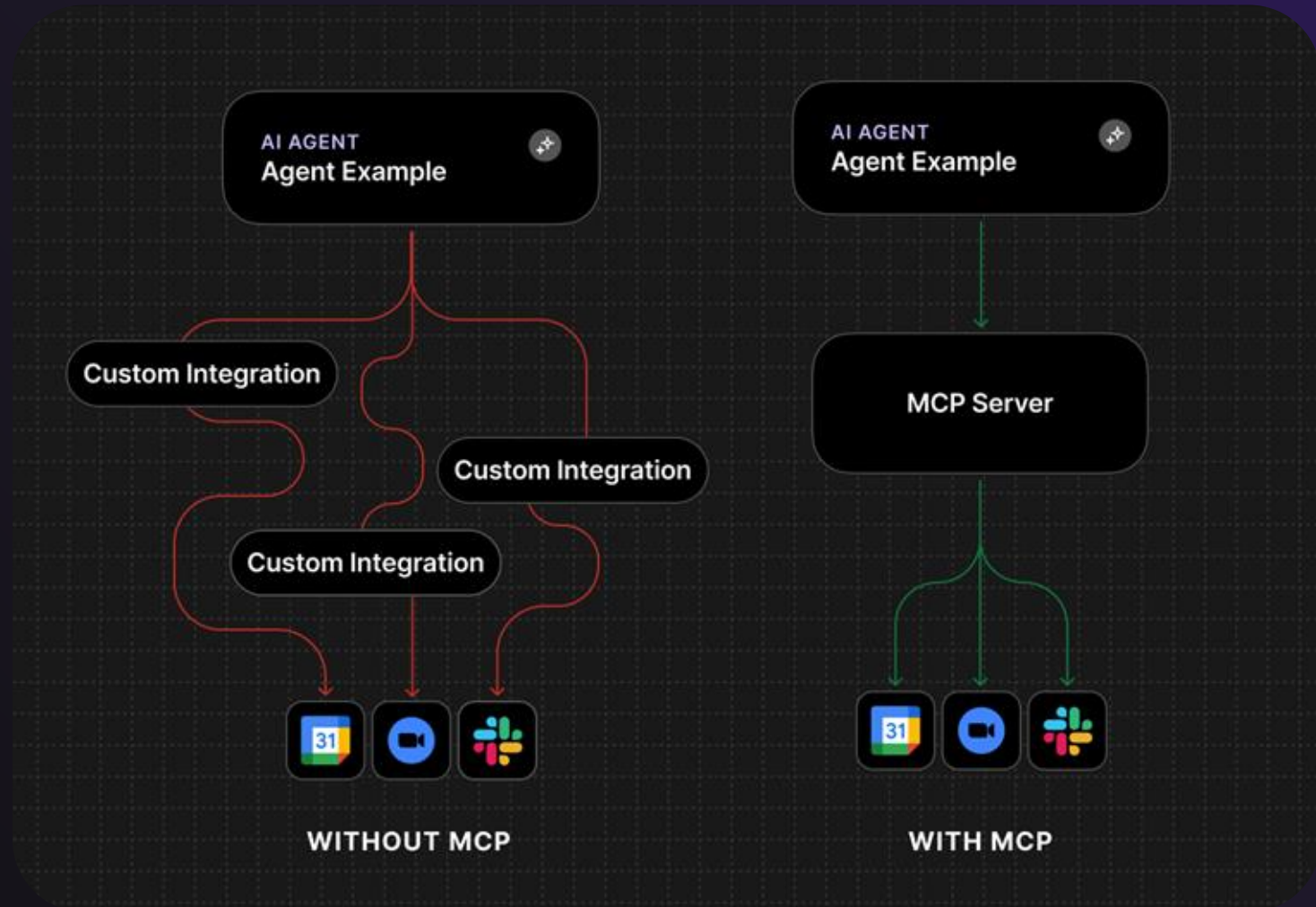
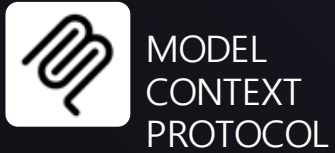
메모리에 저장된 내용 및 기존 업무 맥락을 바탕으로 여러 툴을 넘나들며 여러 단계로 구성된 업무를 수행합니다

Anthropic

일반적인 AI Agent 앱 구성



AI Agent 기능 확장의 핵심: MCP



AI 앱을 개발하고 운용할 때 보안을 고려하고 있나요?



Marc Benioff

@Benioff

Amazing. "Organizations are reportedly reluctant to integrate Copilot into their workflow because of the tool's capabilities to bypass critical security measures and access private credentials that would ordinarily require high-level clearance."



David Fowler

@davidfowl

I know we're talking about how the future is "agentic" but who is solving the security/auth problem? These agents need to have access the systems you have access to (probably with limited permissions) and need to be able to act on your behalf.



Alex Albert

@alexalbert__

We just published a near-term development roadmap for the model context protocol (MCP)

Some highlights:

- Remote support (and auth!)
- Reference implementations
- Better package management
- Agent support



생성형 AI의 보안에 대한 몇 가지 오해

에이전트가 API Key를 사용해도
아무런 문제가 없다



API 키는 에이전트가 아닌 앱을 위해 디자인되어, 사용자별 컨텍스트나 세분화된 권한을 포함하지 않음. API 키는 정책적 안전장치 없이 에이전트가 모든 사용자 데이터에 접근할 수 있도록 허용할 수도 있음

프롬프트만 적절하다면
LLM은 항상 안전하게 작동한다



프롬프트 엔지니어링은 위험을 줄일 수 있지만 정책을 강제할 수는 없음. 정책, 권한 부여, Rate Limit 및 필터링은 모델 외부에서, 여러분이 제어하는 코드 내에서 이루어져야 함

AI는 사용자가 누군지
당연히 알고 있다



로그인 없이 누구나 다른 사람인 척할 수 있음.
신원 확인 없음 = 개인화나 접근 제어 없음.

사용자 승인은 암묵적이다
"예" = 동의



동의를 특히 민감한 행위 및 규제 산업의 경우 명시적이고 검증 가능하며 기록되어야 합니다.

LLM은 사용자에게
인증 정보를 요청할 수 있다



LLM에 텍스트로 비밀 정보를 제공해서는 안 됩니다. 모델에는 데이터와 인증 정보 및 비밀 정보를 구분할 수단이 없습니다.

에이전트의 리소스에 대한
접근 제어는 사전에 지정될 수 있다



에이전트는 새로운 정보를 발견하고 동적으로 추가 리소스에 대한 접근을 요청할 수도 있음

AI로 인해 초래될 수 있는 보안 위협



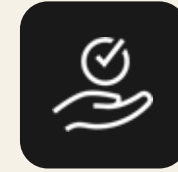
인가되지 않은 데이터 접근

에이전트가 사용자에게 접근이 허용되지 않은 데이터를 가져올 수 있음



불필요하거나 과도한 권한 부여

Role 또는 Token 관리에 소홀하면 에이전트가 아무도 모르게 강력한 권한을 가질 수 있음



컴플라이언스 및 감사 허점

에이전트의 활동이 실제 사용자 및 기록된 동의와 연결되지 않으면 정확한 보안 감사에 실패할 수 있음



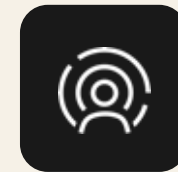
취약하거나 세분화되지 않은 인가 정책

획일적인 권한 정책이 구성되어 있다면 아무 에이전트나 민감한 작업을 수행할 수 있게 됨



시크릿 및 자격 증명 유출

키나 토큰이 프롬프트에 노출되어 공격자에게 탈취될 수 있음



개인정보 및 데이터 유출 위험

개인정보가 안전한 저장소에서 벗어나 악의적인 제3자에게 넘어갈 수 있음

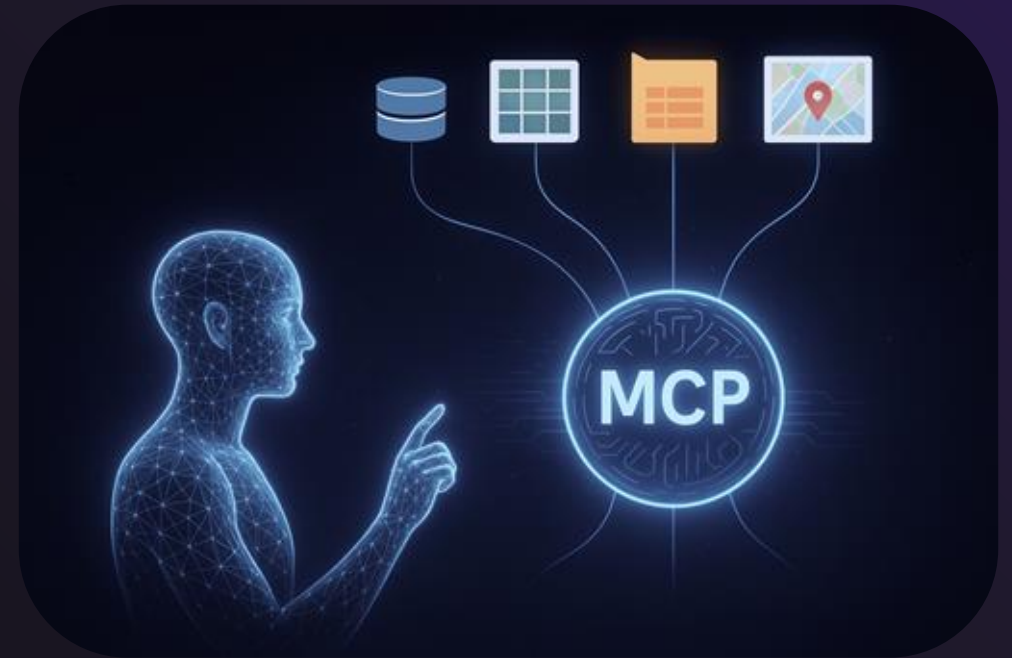


MCP를 적용함으로써 발생하는 문제

모든 AI 에이전트는 MCP 서버의 서비스에 접근하기 위해 안전하게 인증 및 권한 부여가 이루어져야 합니다. 하지만 이 과정의 구현은 서비스 난이도에 따라 빠르게 복잡해질 수 있습니다

MCP는 다양한 도구 및 데이터 소스에 연결됩니다. MCP에 엄격한 안전장치가 마련되지 않으면, AI 에이전트가 너무 많은 권한을 부여받을 수 있습니다: 허용되지 않은 데이터를 수집하거나, 수행해선 안 되는 작업을 실행할 수도 있습니다

거버넌스 및 감사 가능성이 서비스 운영 보안의 성공 여부를 좌우합니다



AI는 사용자가
누구인지를
알아야 합니다



Email

employee@healthzero.com

Password

Log in

Authentication 

User Context



AI는 사용자 대신
API를 호출할 수
있어야 합니다



Tokens



Tool Access



AI는 비동기
상호작용을
수행합니다



Consent



User Approval



AI 데이터는 사용자
의 권한을 고려해야
합니다



Fine-grained authorization

RAG



AI 개발자를 위한 Okta의 솔루션

1

Auth0 for AI Agents

2

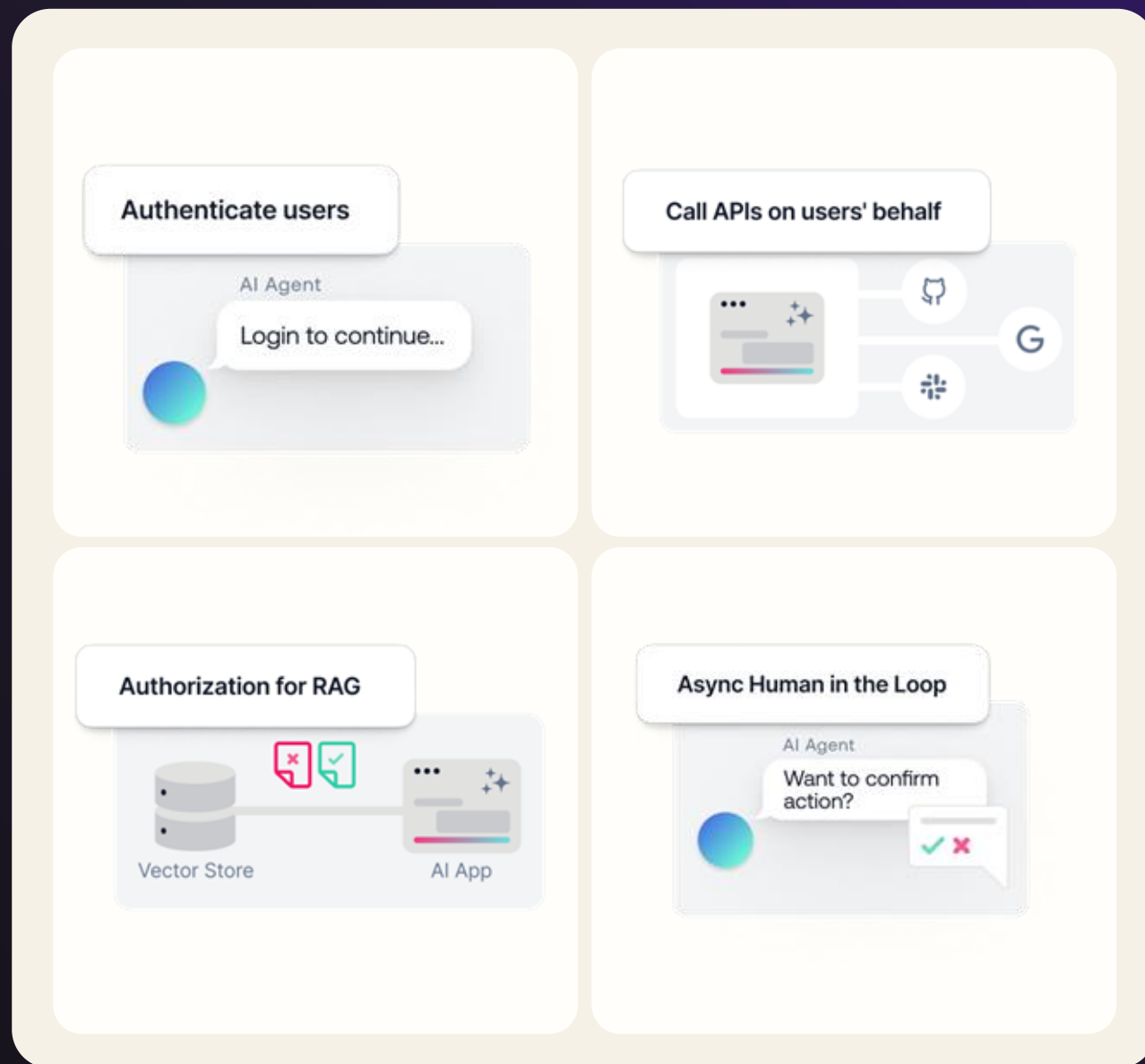
Auth for MCP

Auth for GenAI

GenAI 앱을 더욱 안전하고 쉽게 구축하세요

Auth for GenAI는 AI 에이전트가 사용자를 대신하여 안전하게 API를 호출할 수 있도록 지원하는 강력한 기능 모음입니다.

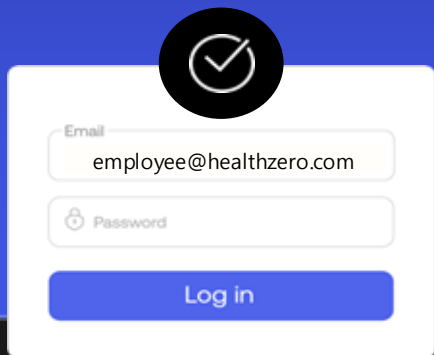
'최소 권한 원칙'에 따라 사용자의 민감한 정보에 꼭 필요한 접근 권한만을 요청함으로써, 대화형 (interactive) 및 비동기(asynchronous) 방식 모두에서 높은 수준의 보안을 유지합니다.



Auth0 for AI Agent 구성요소

사용자 인증

AI needs to know who I am



Quickstart

토큰 볼트

AI needs to call APIs on users behalf



비동기 인가

AI uses async interactions



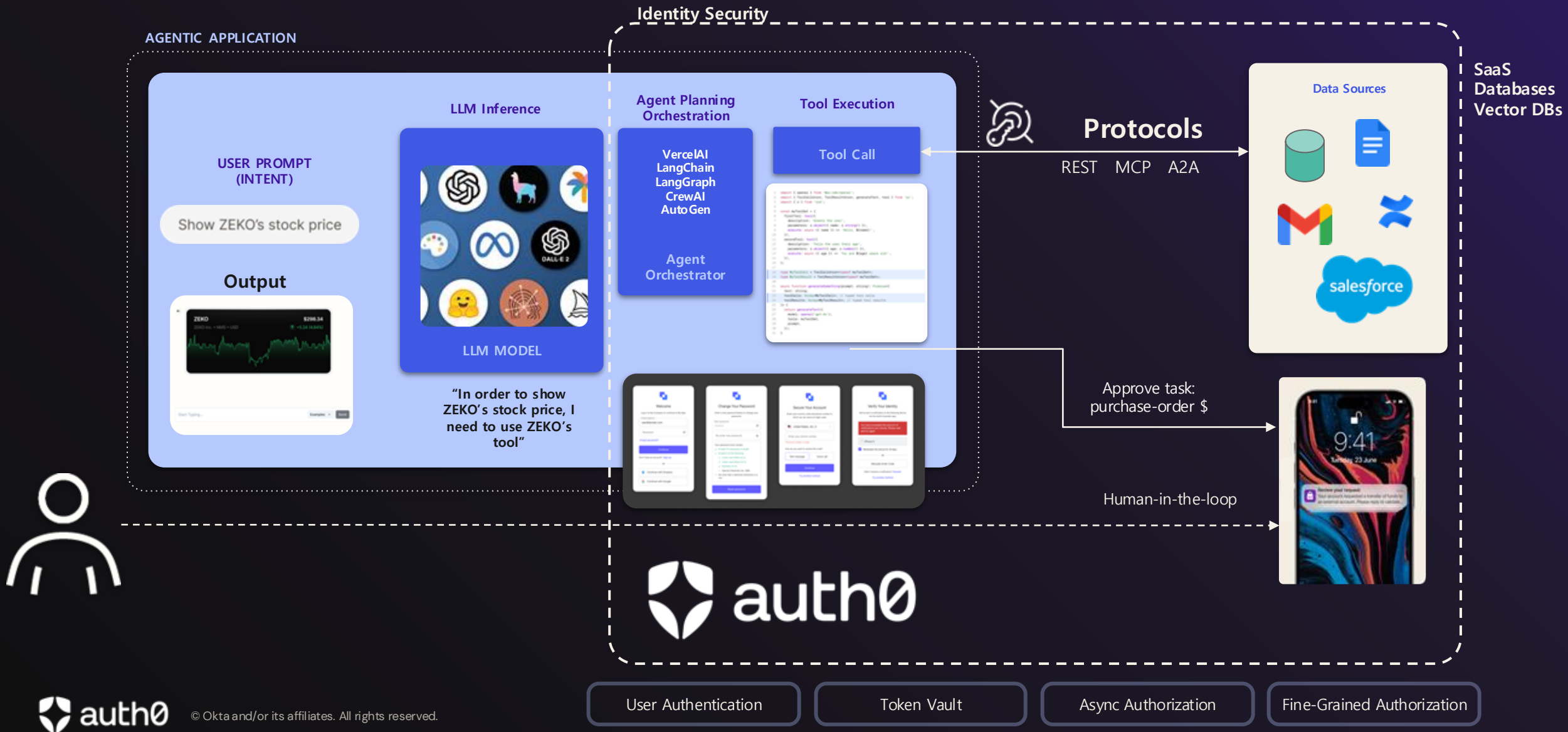
SDKs

관계형 세부 인가 (FGA)

AI data access must consider user permissions



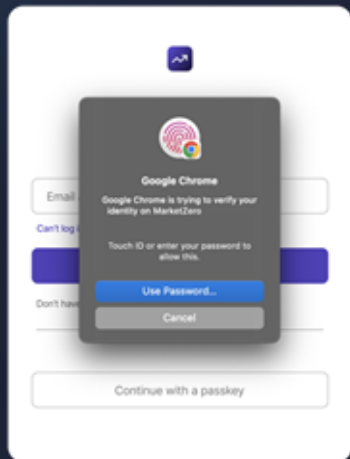
Auth0로 안전하게 보호되는 AI Agent 앱



모든 AI Agent 앱을 위한 사용자 인증

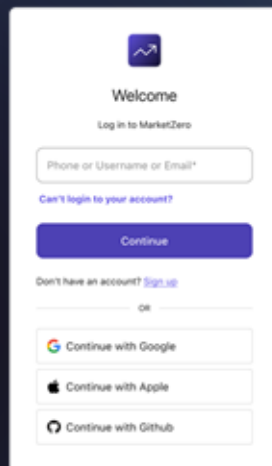
B2C 고객과 B2B 고객을 모두 수용할 수 있는 단일 아이덴티티 시스템

개인고객



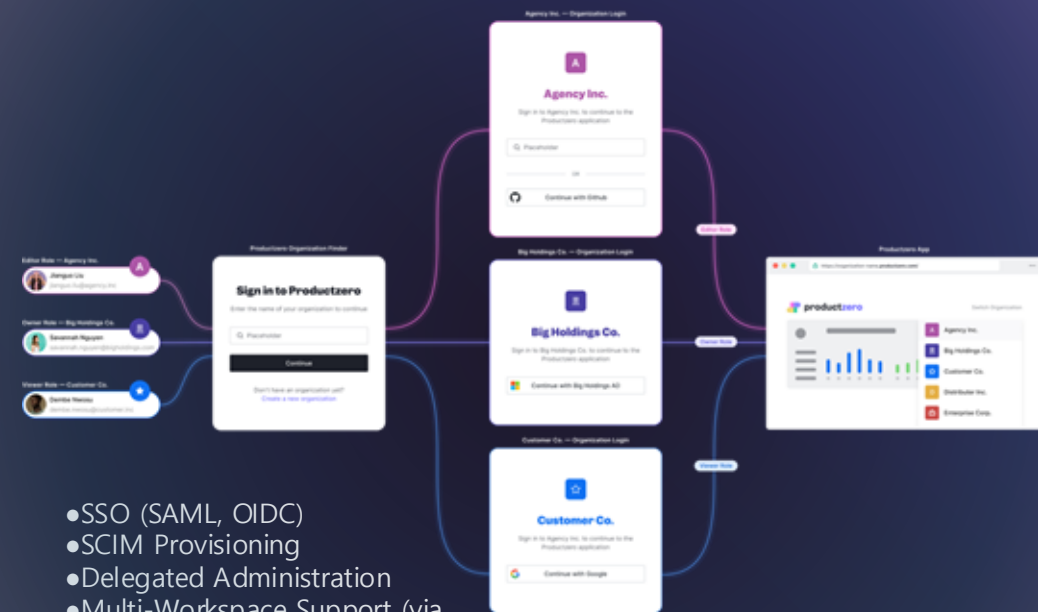
Passwordless options

- Passkeys
- OTP
- Email



Social Login
Flexible Identifiers

기업고객



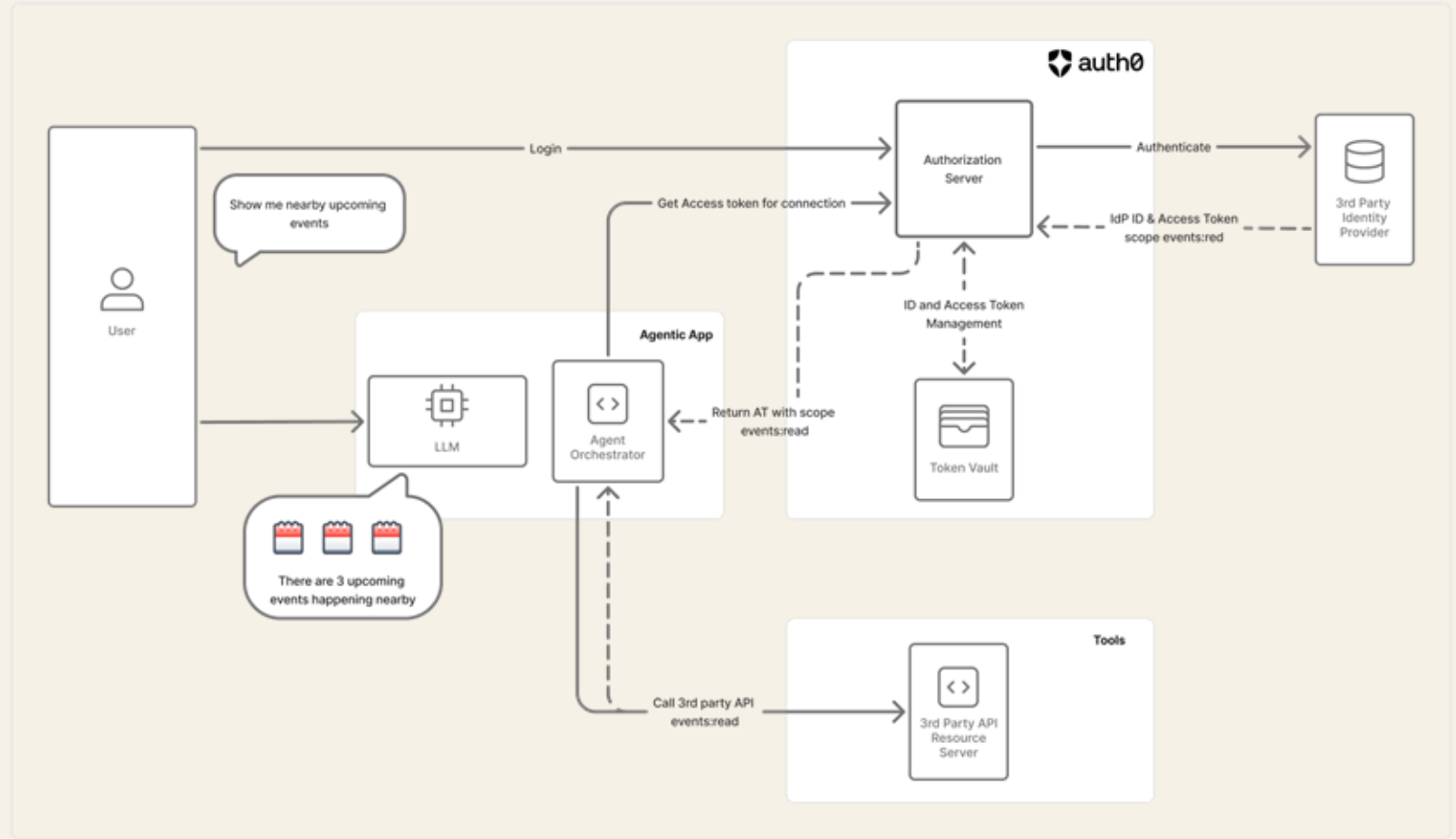
- SSO (SAML, OIDC)
- SCIM Provisioning
- Delegated Administration
- Multi-Workspace Support (via Organizations)

유니버설 로그인 · MFA · 봇 탐지 기능 · 점진적 고객 프로파일링 · 세션 관리 · 완전한 UI 커스터마이제이션

Auth0 Token Vault

서드파티 API에 안전하고 편리하게 접근할 수 있도록 Auth0에서 해당 토큰을 관리 및 처리

- Auth0 내 **안전한 저장소**에 서드파티 Access Token이 저장되고 암호화됩니다
- **페더레이션된 토큰 교환**: 사용자 동의하에 Gmail, Slack, GitHub 및 기타 서비스에 위임된 접근을 가능하게 합니다
- **자동 토큰 관리**: Auth0이 갱신 토큰과 토큰 교환을 자동으로 처리하므로, 별도의 맞춤형 OAuth 로직이 필요 없습니다.

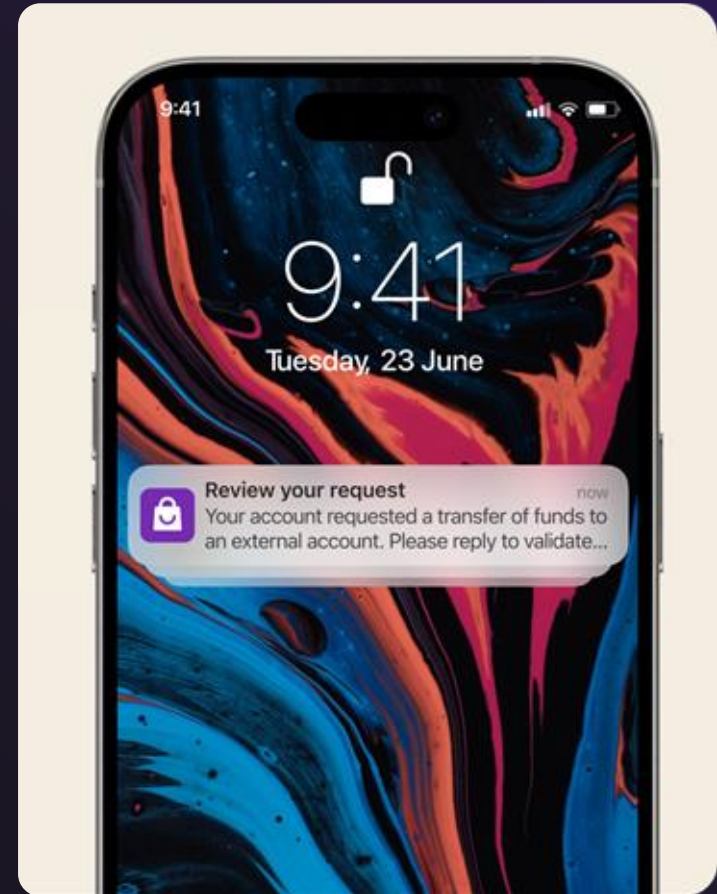


플랫폼 보안 기능을 통해 long-lived token의 노출을 최소화

Human-in-the-loop (HITL) 프레임워크

AI 에이전트가 사용자에게 안전하게 의사 결정을 요청할 수 있도록 지원합니다.

- AI 자율성과 사용자 제어의 균형
 - 민감한 작업에 대한 거버넌스 모델
 - 사용자가 에이전트 동작을 승인, 거부하거나 재정의
-
- 사용자 개입이 필요한 시점
 - 민감한 데이터 접근
 - 통신 또는 외부 시스템 작업
 - 워크플로우 에스컬레이션



Auth0 Fine-Grained Authorization (FGA)

Relationship-based Access Control (ReBAC)

인가 모델 (Authorization Model)

```
model
  schema 1.1

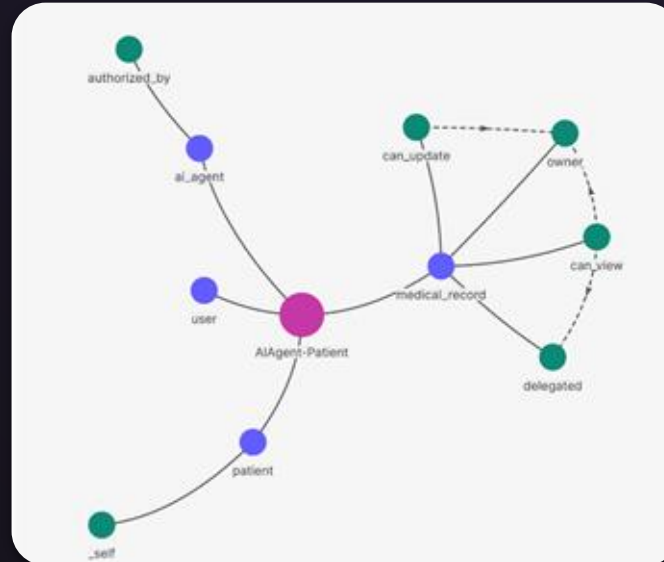
  type user
  type patient
  type ai_agent
  type medical_record

  type patient
  relations
    define _self: [user]

  type ai_agent
  relations
    define authorized_by: [patient]

  type medical_record
  relations
    define can_update: owner
    define can_view: owner or delegated
    define delegated: [ai_agent#authorized_by]
    define owner: [patient]
```

관계성 그래프 (Relationship Graph)



권한 데이터 (Permission Tuples)

USER	patient:john_doe
OBJECT	medical_record:mr_333
RELATION	owner

USER	patient:john_doe
OBJECT	ai_agent:ai_111
RELATION	authorized_by

USER	ai_agent:ai_111#authorized_by
OBJECT	medical_record:mr_333
RELATION	delegated

Auth0 FGA를 이용한 RAG 파이프라인 관리



1. User Prompt

"내 최근 미팅 일정을 보여줘"



2. Retrieve

AI Agent가 vector store에서
관련 문서를 검색



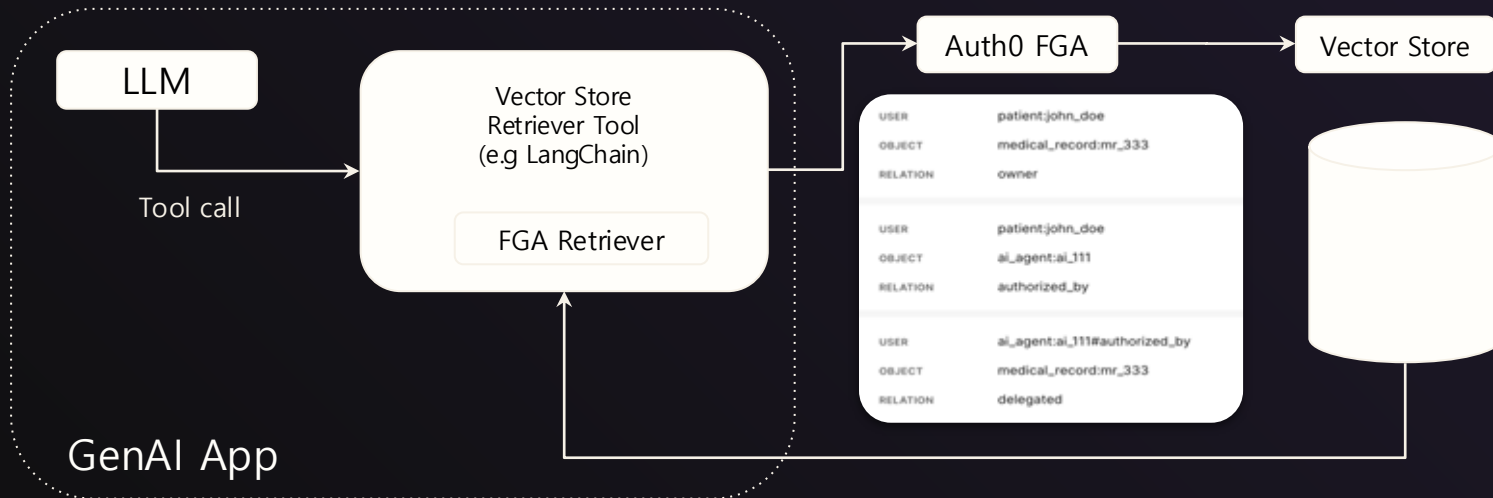
3. Filter

FGA가 사용자 권한에 따라
문서를 필터링



4. Answer

Agent는 사용자에게 접근이
승인된 문서만 볼 수 있음



Example: LangChain + FGA integration

```
14 const user = "user1";
15 // 1. Read and load documents from the assets folder
16 const documents = await readDocuments();
17 // 2. Create an in-memory vector store from the documents for OpenAI models.
18 const vectorStore = await MemoryVectorStore.fromDocuments(
19   documents,
20   new OpenAIEmbeddings({ model: "text-embedding-3-small" })
21 );
22 // 3. Create a retriever that uses FGA to gate fetching documents on permissions.
23 const retriever = FGARetriever.create({
24   retriever: vectorStore.asRetriever(),
25   // FGA tuple to query for the user's permissions
26   buildQuery: (doc) => ({
27     user: `user:${user}`,
28     object: `doc:${doc.metadata.id}`,
29     relation: "viewer",
30   }),
31 });
32 // 4. Convert the retriever into a tool for an agent.
33 const fgaTool = retriever.asJoinedStringTool();
34 // 5. The agent will call the tool, rephrasing the original question and
35 // populating the "query" argument, until it can answer the user's question.
36 const retrievalAgent = RetrievalAgent.create([fgaTool]);
37 // 6. Query the retrieval agent with a prompt
38 const answer = await retrievalAgent.query("Show my last appointment record");
```

Auth0 for AI Agent는 안전한 AI 에이전트를 쉽고 빠르게 만들 수 있는 다양한 기능을 제공합니다



AI Agent
사용자 인증



토큰 볼트



비동기 인가



RAG를 위한 Fine-
Grained
Authorization
(FGA)

Auth for MCP

MCP는 AI 에이전트의 능력을 확장합니다. Auth0는 이러한 에이전트에 신뢰성을 부여합니다.

권한 통제

범위 지정, 신원 기반, 최소 권한 접근
자체 개발 AI 에이전트 및 서드 파티 AI 에이전트 모두 적용 가능



권한 관리

사용자 동의 플로우 및 클라이언트별 권한



보안성 강화

Token Vault 및 Token Exchange를 통한 자격 증명

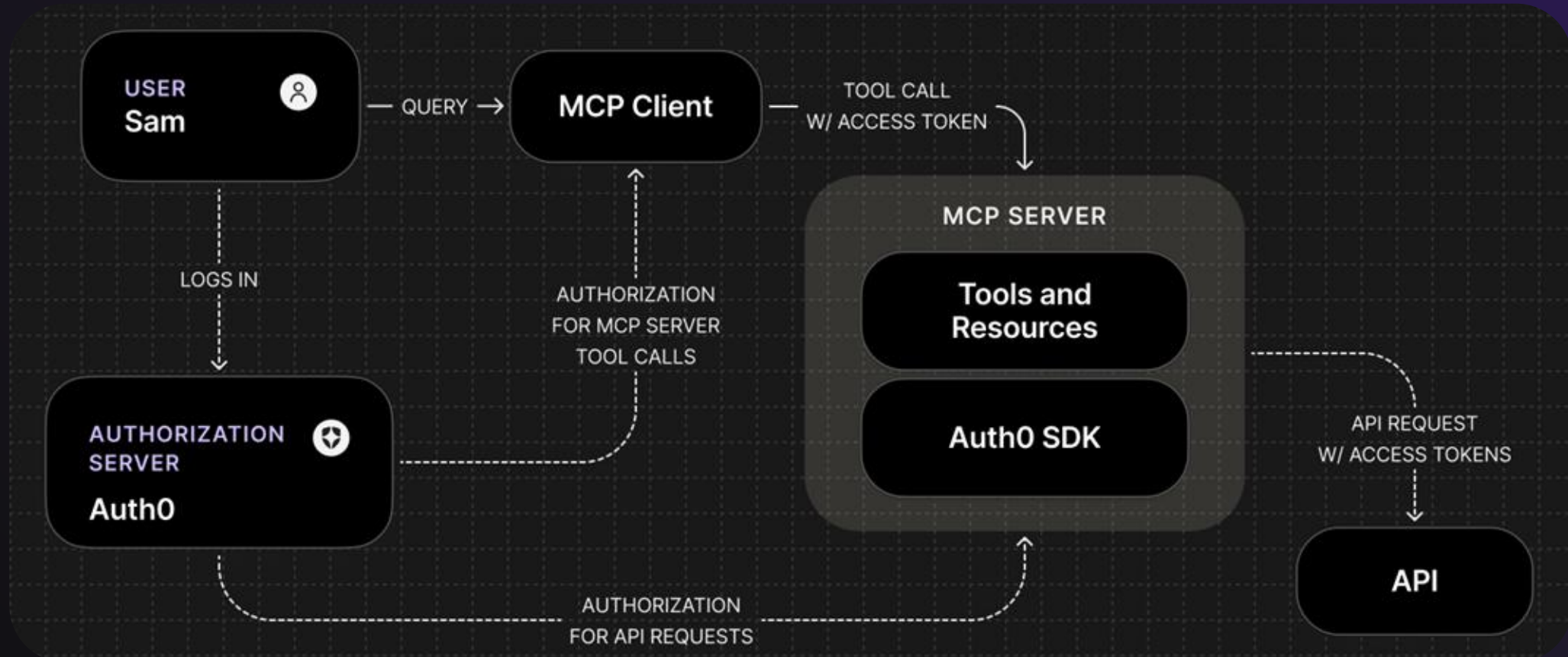


감사 가시성 확보

감사, 라이프사이클 이벤트 및 접근 가시성



How Auth for MCP works



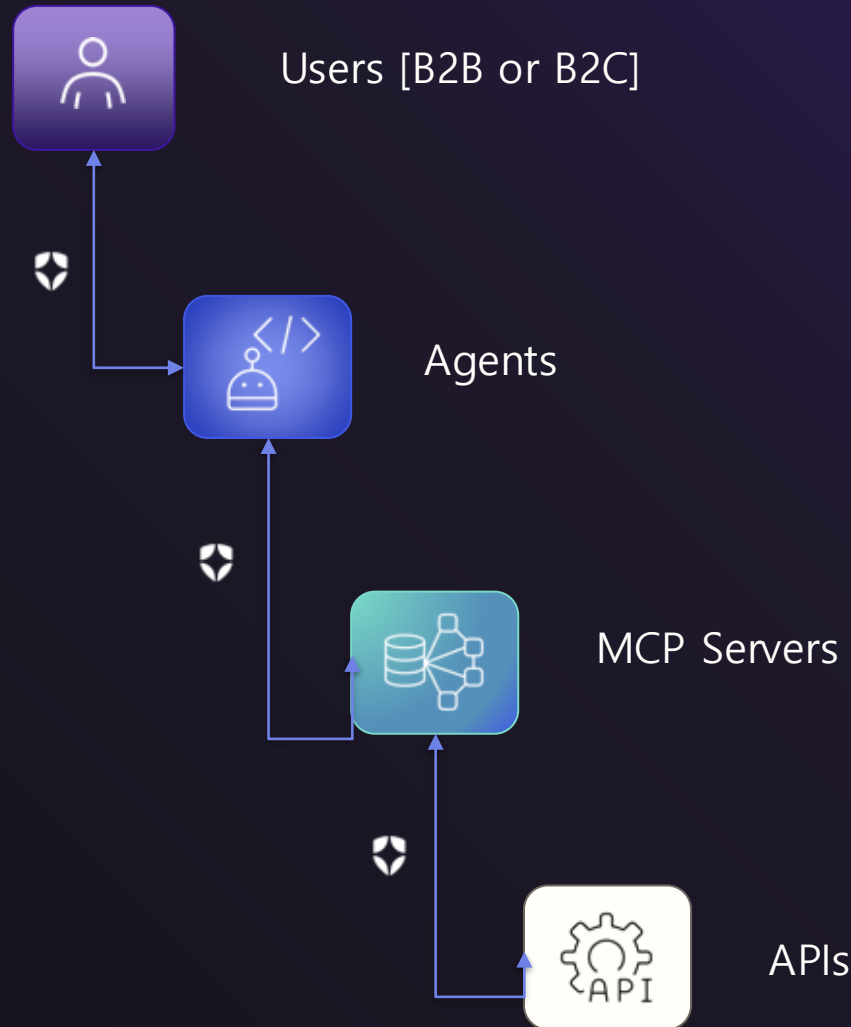
The Agentic Iceberg



Why Auth for MCP



Auth0는 AI 에이전트 구성의 모든 영역을 보호합니다.



AI 에이전트 보안을 위한 업계 최고의 솔루션



보안성

앱에 AI를 도입할 때 사용자 경험의 불편함을 최소화하면서 보안은 강화하세요



확장성

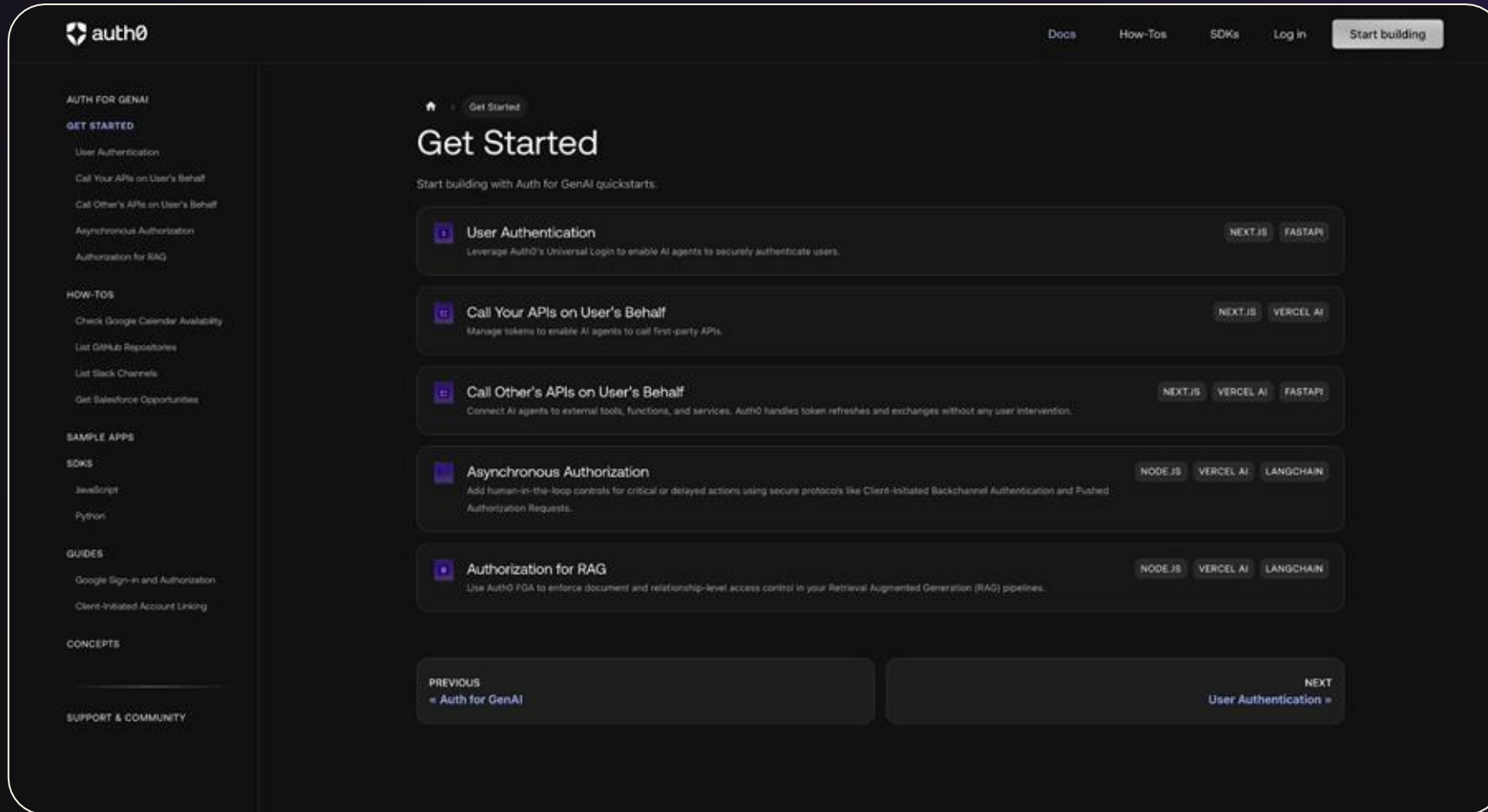
앱과 에이전트가 성장하면서 수억 명의 사용자까지 원활하게 확장 가능합니다



개발자 편의성

아이덴티티 관련 최고의 개발자 도구 (SDK, 퀵스타트 가이드 등)를 제공하여, 개발자는 보안이 아닌 AI 앱 개발이라는 본연의 업무에 집중할 수 있습니다

안전한 AI 에이전트 개발, Auth0와 함께 시작하세요



Available now on
[**auth0.com/ai**](https://auth0.com/ai)

Start your GenAI identity security journey with a Quickstart guide.



Thank you!

궁금하신 내용은 Okta 부스 방문하시거나
heejae.chang@okta.com으로 연락해주세요!